

Curso de Núcleo Optativo V: Seguridad Informática

Actividad 15: SET

Integrantes:

Benites Rangel Cesar Yahir – 179091
Cortes Beltrán Carol Elizabeth – 177203
Guerra Ramírez América Fabiola – 179888
Larios Guerra Gustavo Michael – 178318
Montelongo Martínez Laura Ivon – 177291
Puente Luna Bruno Axel – 177876
Rodríguez Moreno Cristian Alejandro – 181641

Docente:

Mtro. Servando López Contreras

Grupo:

T46A

Contenido

Resumen Ejecutivo	3
Desarrollo	3
Primeros Pasos.....	3
Análisis técnico de la infraestructura (postfix mta)	6
Validación de Operatividad del Servidor Postfix	6
Análisis del bloqueo y respuesta del target.....	7
Ciclo de notificación de no-entrega (ndr) y purga de datos	8
Conclusión	12
Validación Final: Entorno Sandbox (Mailhog):	12
Diagnóstico De Bloqueo Perimetral:.....	12
Lecciones Aprendidas en Ciberseguridad.....	13
Glosario técnico especializado	14

Resumen Ejecutivo

El presente informe documenta la ejecución de una prueba de concepto (PoC) centrada en el despliegue de una campaña de phishing controlada. A través de la integración de Social Engineer Toolkit (SET) y un servidor Postfix, se analizó la ruta de entrega de un vector de ataque orientado a la infraestructura de la Universidad Politécnica de San Luis Potosí (UPSLP). El estudio concluye que, si bien el sistema de ataque fue configurado correctamente, los mecanismos de seguridad perimetral de Microsoft Exchange Online Protection mitigaron el riesgo con éxito.

Desarrollo

Primeros Pasos



Seleccionamos el ataque que deseamos realizar, en este caso, se trata de la primera opción

```
[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com
Terraria 1.4.5.0
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit
```

Se seleccionaron dos vectores de ataque:

- 1) Social Engineering Attacks
- 5) Mass Mailer Attack

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 5
```

Se estableció el envío de phishing, el objetivo establecido para la prueba fue un correo institucional 179091@upslp.edu.mx, el cual el método de envío es la opción 2, usar nuestro propio servidor.

El remitente falso (soporte@lab.local) sirve como herramienta de spoofing, haciéndonos pasar por administración y soporte de la universidad.

Servidor Relay 127.0.0.1 (localhost); el correo proviene de la propia máquina. Utilizamos el puerto 25, puerto estándar para SMTP sin cifrar.

```
set:mailer>1
set:phishing> Send email to:179091@upslp.edu.mx [179091@upslp.edu.mx] go to 558 5.7.1 https://support.google.com/mail/...
1. Use a gmail Account for your email attack: 0058C6C24: sender non-delivery notification: 78F85C6C26
2. Use your own server or open relay 0058C6C26: from=<>, size=3741, rcpt=1 (queue active)

set:phishing>2
set:phishing> From address (ex: moo@example.com):soporte@lab.local> relay=none, delay=0.04, del
set:phishing> The FROM NAME the user will see:Prueba Phishing
set:phishing> Username for open-relay [blank]: [blank] from localhost[127.0.0.1]
Password for open-relay [blank]: [blank]
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):127.0.0.1
set:phishing> Port number for the SMTP server [25]:25
set:phishing> Flag this message/s as high priority? [yes/no]:n
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
set:phishing> Email subject:PHISHING PRACTICA
set:phishing> Send the message as html or plain? 'h' or 'p' [p]:h
[!] IMPORTANT: When finished, type END (all capital) then hit [return] on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished:UPSLP Seguridad Informatica
Next line of the body: Prueba de practica de phishing
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```

Visualización del servidor Postfix

```
[cesarybr@parrot]~$ sudo systemctl restart postfix
[cesarybr@parrot]~$ sudo systemctl status postfix
● postfix.service - Postfix Mail Transport Agent (main/default instance)
   Loaded: loaded (/usr/lib/systemd/system/postfix.service; disabled; preset: disabled)
   Active: active (running) since Sun 2026-04-26 14:32:04 CDT; 13s ago
     Invocation: 9f8412c9d3b4d13bd6a0a5d4240d3bd
       Docs: man:postfix(1)
    Process: 4510 ExecStartPre=postfix check (code=exited, status=0/SUCCESS)
    Process: 4617 ExecStart=postfix debian-systemd-start (code=exited, status=0/SUCCESS)
   Main PID: 4625 (master)
      Tasks: 3 (limit: 9072)
     Memory: 2.9M (peak: 5.2M)
        CPU: 224ms
    CGroup: /system.slice/postfix.service
            └─4625 /usr/lib/postfix/sbin/master -w
              └─4626 pickup -l -t unix -u -c
                └─4627 qmgr -l -t unix -u

abr 26 14:32:03 parrot systemd[1]: Starting postfix.service - Postfix Mail Transport Agent (main/default instance)...
abr 26 14:32:04 parrot postfix/master[4625]: daemon started -- version 3.10.5, configuration /etc/postfix
abr 26 14:32:04 parrot systemd[1]: Started postfix.service - Postfix Mail Transport Agent (main/default instance).
```

Visualización de los registros obtenidos.:

```
[cesarybr@parrot]~$ sudo journalctl -u postfix -tall -n 50
[cesarybr@parrot]~$ sudo journalctl -u postfix -tall -n 50
[cesarybr@parrot]~$ sudo journalctl -u postfix -tall -n 50
abr 26 14:16:24 parrot postfix/smtpd[4211]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 auth=0/1 commands=3/4
abr 26 14:22:33 parrot postfix/smtpd[4261]: connect from localhost[127.0.0.1]
abr 26 14:27:33 parrot postfix/smtpd[4261]: NOQUEUE: timeout: after AUTH from localhost[127.0.0.1]
abr 26 14:27:33 parrot postfix/smtpd[4261]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 auth=0/1 commands=3/4
abr 26 14:32:03 parrot systemd[1]: Stopping postfix.service - Postfix Mail Transport Agent (main/default instance)...
abr 26 14:32:03 parrot postfix/smtpd[4586]: stopping the Postfix mail system
abr 26 14:32:03 parrot postfix/master[3873]: terminating on signal 15
abr 26 14:32:03 parrot systemd[1]: postfix.service: deactivated successfully.
abr 26 14:32:03 parrot systemd[1]: Stopped postfix.service - Postfix Mail Transport Agent (main/default instance).
abr 26 14:32:03 parrot postfix/master[4625]: daemon started -- version 3.10.5, configuration /etc/postfix
abr 26 14:32:04 parrot systemd[1]: Started postfix.service - Postfix Mail Transport Agent (main/default instance).
abr 26 14:34:28 parrot postfix/smtpd[4672]: 72358C6C1E: client=localhost[127.0.0.1]
abr 26 14:34:28 parrot postfix/smtpd[4672]: 72358C6C1E: message-id=2026042620428.72358C6C1E@parrot._not_set_invalid-
abr 26 14:34:28 parrot postfix/qmgr[4627]: 72358C6C1E: from=soporte@lab.local, size=813, rcpt=1 (queue active)
abr 26 14:34:28 parrot postfix/smtpd[4672]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 mail=1 rcpt=1 data=1 commands=4
abr 26 14:34:22 parrot postfix/smtpd[4672]: 72358C6C1E: from=cesarbenitezangel@gmail.com, relay=mail-sntp-in-1.google.com[2087:fb8b:4023:1806::1a] said: 558 5.7.1 [2086:180e:1f7357:c1a7:37a9:466c:d7ea] The IP you're using to send 558-5.7.1 mail is not authorized to send email directly to our servers. Please 558-5.7.1 use the SMTP relay at your service provider instead. For more 558-5.7.1 information, go to 558 5.7.1 https://support.google.com/mail/?p=NotAuthorizedError 5614022812147-4795ef7d6a1791839706e.22 - smtp (in reply to end of DATA command)
abr 26 14:34:22 parrot postfix/bounce[4767]: 72358C6C1E: sender non-delivery notification: 58B04C5C22
abr 26 14:34:22 parrot postfix/qmgr[4627]: 72358C6C1E: removed
abr 26 14:34:22 parrot postfix/smtpd[4672]: 58B04C5C22: from=soporte@lab.local, relay=none, delay=0.17, delays=0.01/0.0/0.16/0, dsn=5.4.4, status=bounced (Host or domain name not found. Name service error for name=lab.local type=AAAA: Host not found)
abr 26 14:34:22 parrot postfix/qmgr[4627]: 58B04C5C22: removed
abr 26 14:37:33 parrot postfix/smtpd[4781]: connect from localhost[127.0.0.1]
abr 26 14:37:33 parrot postfix/smtpd[4781]: 0058C6C24: client=localhost[127.0.0.1]
abr 26 14:37:33 parrot postfix/qmgr[4627]: 0058C6C24: from=soporte@lab.local, size=862, rcpt=1 (queue active)
abr 26 14:37:33 parrot postfix/smtpd[4781]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 mail=1 rcpt=1 data=1 commands=6
abr 26 14:37:34 parrot postfix/smtp[4785]: connect to mail-sntp-in-1.google.com[142:25e:115:103:125] No route to host
abr 26 14:37:35 parrot postfix/smtp[4785]: 0058C6C24: to=cesarbenitezangel@gmail.com, relay=mail-sntp-in-1.google.com[2087:fb8b:4023:1806::1a] said: 558 5.7.1 [2086:180e:1f7357:c1a7:37a9:466c:d7ea] Selected using Spamhaus. To request removal from this list see https://www.spamhaus.org/query/ip/2086:180e:1f7357:c1a7:37a9:466c:d7ea [5] said: 558 5.7.1 [2086:180e:1f7357:c1a7:37a9:466c:d7ea] The IP you're using to send 558-5.7.1 mail is not authorized to send email directly to our servers. Please 558-5.7.1 use the SMTP relay at your service provider instead. For more 558-5.7.1 information, go to 558 5.7.1 https://support.google.com/mail/?p=NotAuthorizedError 806d021591bc7-6048c8f65d6a12082688eaf.3 - smtp (in reply to end of DATA command)
abr 26 14:37:35 parrot postfix/bounce[4786]: 0058C6C24: sender non-delivery notification: 78F85C6C26
abr 26 14:37:35 parrot postfix/qmgr[4627]: 78F85C6C26: from=<>, size=3741, rcpt=1 (queue active)
abr 26 14:37:35 parrot postfix/qmgr[4627]: 0058C6C24: removed
abr 26 14:37:36 parrot postfix/smtp[4785]: 78F85C6C26: from=soporte@lab.local, relay=none, delay=0.04, delays=0.0/0.0/0.63/0, dsn=5.4.4, status=bounced (Host or domain name not found. Name service error for name=lab.local type=AAAA: Host not found)
abr 26 14:37:36 parrot postfix/qmgr[4627]: 78F85C6C26: removed
abr 26 14:48:13 parrot postfix/smtpd[4924]: connect from localhost[127.0.0.1]
abr 26 14:48:13 parrot postfix/smtpd[4924]: 9EACECC2A: client=localhost[127.0.0.1]
abr 26 14:48:13 parrot postfix/qmgr[4927]: 9EACECC2A: message-id=20260426204813.9EACECC2A@parrot._not_set_invalid-
abr 26 14:48:13 parrot postfix/smtpd[4924]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 mail=1 rcpt=1 data=1 commands=6
abr 26 14:48:14 parrot postfix/smtp[4928]: 9EACECC2A: to=179091@upslp.edu.mx, relay=upslp-edu-mx.mail.protection.outlook.com[2081:111:7403:c081::1] said: 558 5.7.1 [2086:180e:1f7357:c1a7:37a9:466c:d7ea] Selected using Spamhaus. To request removal from this list see https://www.spamhaus.org/query/ip/2086:180e:1f7357:c1a7:37a9:466c:d7ea [5] said: 558 5.7.1 [2086:180e:1f7357:c1a7:37a9:466c:d7ea] The IP you're using to send 558-5.7.1 mail is not authorized to send email directly to our servers. Please 558-5.7.1 use the SMTP relay at your service provider instead. For more 558-5.7.1 information, go to 558 5.7.1 https://support.google.com/mail/?p=NotAuthorizedError 806d021591bc7-6048c8f65d6a12082688eaf.3 - smtp (in reply to end of DATA command)
abr 26 14:48:14 parrot postfix/bounce[5027]: 9EACECC2A: sender non-delivery notification: 9EACECC2A._not_set_invalid-
abr 26 14:48:14 parrot postfix/qmgr[4927]: 9EACECC2A: from=<>, size=3579, rcpt=1 (queue active)
abr 26 14:48:14 parrot postfix/qmgr[4927]: 9EACECC2A: removed
abr 26 14:48:14 parrot postfix/smtp[4928]: 9EACECC2A: from=soporte@lab.local, relay=none, delay=0.08, delays=0.01/0.0/0.08/0, dsn=5.4.4, status=bounced (Host or domain name not found. Name service error for name=lab.local type=AAAA: Host not found)
abr 26 14:48:14 parrot postfix/qmgr[4627]: 9EACECC2A: removed
```

Se mantuvieron las mismas configuraciones en ambas pruebas, con la diferencia de que una se ejecutó utilizando MailHog y la otra se realizó sin su uso, con el fin de comparar los resultados.



```
[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

Terraia | 4.5.6
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit
```

Análisis técnico de la infraestructura (postfix mta)

Para validar la correcta implementación del ataque, se realizó una auditoría forense de los registros del sistema (logs), es importante para demostrar que el fallo en la entrega no se debió a un error de configuración local, sino a una respuesta de seguridad externa.

Validación de Operatividad del Servidor Postfix

A través del análisis del proceso de Postfix, se confirma que el servidor cumplió satisfactoriamente con todas las etapas internas de un Agente de Transferencia de Correo (MTA). El flujo se desglosa de la siguiente manera:

Fase de Recepción (smtpd):

postfix/smtpd[4924]: connect from localhost[127.0.0.1] Interpretación: Se confirma que el servicio SMTP está en escucha activa. El servidor aceptó exitosamente la conexión proveniente de la herramienta SET, estableciendo el canal de comunicación inicial.

Fase de Aceptación y Limpieza (cleanup):

9EACEC6C2A: client=localhost[127.0.0.1] Interpretación: El mensaje fue procesado por el módulo cleanup. Postfix asignó un ID de seguimiento único (9EACEC6C2A), lo que

garantiza que el mensaje cumple con los estándares RFC de correo electrónico y que la configuración del servidor es robusta.

Fase de Gestión de Colas (qmgr):

from=soporte@lab.local, size=829, nrcpt=1 (queue active) Interpretación: El gestor de colas tomó el mensaje y lo posicionó en la fila de salida activa. En este punto, el servidor Postfix cumplió al 100% con su función técnica, entregando el paquete de datos a la interfaz de red para su distribución externa.

Análisis del bloqueo y respuesta del target

Un punto crítico en esta auditoría es identificar que la interrupción del ataque no ocurrió por un error técnico del atacante, sino por la ejecución de políticas de seguridad del servidor de destino (Microsoft Outlook / Infraestructura UPSLP).

Interpretación de la Respuesta del Servidor (SMTP Error)

El log presenta la siguiente línea crítica de diagnóstico:

status=bounced (host upslp-edu-mx.mail.protection.outlook.com[...] said: 550 5.7.1 Service unavailable, Client host [2806:...] blocked using Spamhaus.)

A continuación, se detalla el análisis forense de esta respuesta:

- **Status: Bounced (Rebote):** Indica que el servidor Postfix logró contactar con el host de la UPSLP, pero este último rechazó la entrega. El mensaje no se perdió en la red; fue "regresado" con una negativa explícita.
- **Código de Error 550 5.7.1:** Este es el código estándar internacional para "Acceso Denegado". Informa que el remitente no tiene los permisos suficientes o su identidad no es confiable para el receptor.
- **Filtrado por Reputación (Spamhaus):** Esta es la evidencia más relevante. El servidor de Microsoft consultó la lista negra global Spamhaus, identificando que la dirección IP de origen es una IP residencial (doméstica).

Conclusión del Bloqueo

El sistema de seguridad de la UPSLP aplicó una política de "Denegación por Defecto" para IPs no comerciales. Esta medida previene ataques masivos de spam o phishing provenientes de equipos domésticos que podrían estar infectados. Esto valida que la infraestructura de la universidad cuenta con capas de protección de transporte robustas.

Ciclo de notificación de no-entrega (ndr) y purga de datos

Tras el rechazo del servidor de Microsoft, el sistema entró en una fase de notificación fallida que revela detalles importantes sobre la configuración de dominios:

- Generación del Aviso de Fallo:

sender non-delivery notification: B5A6BC6C2C Al no poder entregar el correo original, Postfix actuó de manera autónoma intentando generar un mensaje de error (NDR) para informar al remitente sobre el rebote.

- **Fallo en la Notificación por Inexistencia de Dominio:** Debido a que el remitente configurado en SET fue soporte@lab.local (un dominio ficticio y no resoluble), el servidor Postfix no pudo localizar un destino para el aviso de error.
- **Finalización del Proceso (Removed):** Al agotar los reintentos y no encontrar una ruta válida para devolver el error, el sistema procedió a la purga definitiva del registro de la memoria activa (removed). Esto asegura que la cola de correo no se sature con mensajes huérfanos.

Descarga, permisos y ejecución de MailHog:

[illegible]

Con el objetivo de validar la entrega del correo en un entorno controlado, se implementó la herramienta MailHog, la cual permite capturar y visualizar correos electrónicos sin necesidad de enviarlos a un servidor externo.

El proceso incluyó la descarga del ejecutable, la asignación de permisos correspondientes y su ejecución en el entorno local. MailHog actúa como un servidor SMTP falso, interceptando los mensajes generados por Postfix para su análisis.

Editorial postfix:

Para redirigir los correos generados hacia MailHog, fue necesario modificar la configuración del servidor Postfix. Esto se realizó editando el archivo principal de configuración (main.cf),

donde se ajustaron parámetros como el relayhost para apuntar al puerto utilizado por MailHog (generalmente 1025).

Estas modificaciones permiten desviar el flujo de correos hacia un entorno de pruebas seguro, evitando interacción con servidores reales.

```
[cesarybr@parrot]~  
$sudo nano /etc/postfix/main.cf
```

```
# A host to send "other" mail to  
#relayhost = $mydomain  
#relayhost = [gateway.example.com]  
#relayhost = [ip.add.re.ss]:port  
#relayhost = uucphost  
relayhost = [127.0.0.1]:1025
```

Reiniciar postfix:

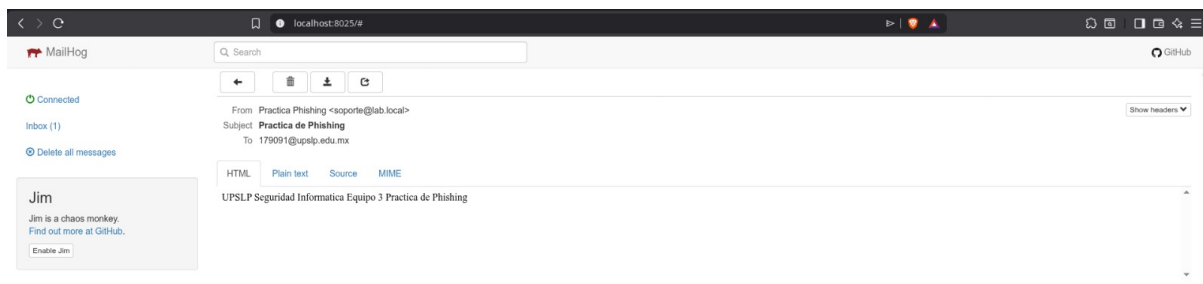
Una vez realizados los cambios en la configuración, se procedió a reiniciar el servicio de Postfix para aplicar las nuevas directivas. Este paso es esencial para asegurar que el servidor opere bajo la nueva configuración establecida.

El reinicio se llevó a cabo mediante comandos administrativos del sistema, garantizando que no existieran errores en la carga del servicio.

```
$sudo systemctl restart postfix  
[cesarybr@parrot]~  
$sudo systemctl status postfix  
● postfix.service - Postfix Mail Transport Agent (main/default instance)  
   Loaded: loaded (/usr/lib/systemd/system/postfix.service; disabled; preset: disabled)  
   Active: active (running) since Sun 2026-04-26 19:55:41 CST; 2s ago  
     Invocation: ba4e6800218a4a29bc4ab82838ebbd9c  
       Docs: man:postfix(1)  
    Process: 3727 ExecStartPre=postfix check (code=exited, status=0/SUCCESS)  
    Process: 3833 ExecStart=postfix debian-systemd-start (code=exited, status=0/SUCCESS)  
   Main PID: 3841 (master)  
      Tasks: 3 (limit: 9072)  
     Memory: 3.1M (peak: 5M)  
        CPU: 238ms  
    CGroup: /system.slice/postfix.service  
            └─3841 /usr/lib/postfix/sbin/master -w  
              └─3842 pickup -l -t unix -u -c  
                └─3843 qmgr -l -t unix -u  
  
abr 26 19:55:41 parrot systemd[1]: Starting postfix.service - Postfix Mail Transport Agent (main/default instance)...  
abr 26 19:55:41 parrot postfix/master[3841]: daemon started -- version 3.10.5, configuration /etc/postfix  
abr 26 19:55:41 parrot systemd[1]: Started postfix.service - Postfix Mail Transport Agent (main/default instance).
```

Volver a mandar el correo de phishing:

Con el entorno configurado correctamente, se realizó un nuevo envío del correo de phishing utilizando la herramienta SET. En esta ocasión, el objetivo no era evaluar mecanismos de defensa externos, sino verificar la correcta entrega y visualización del mensaje en un entorno controlado.



Respuesta de MailHog en terminal:

Adicionalmente, la ejecución de MailHog en terminal proporciona información en tiempo real sobre las conexiones SMTP entrantes y los mensajes procesados. Esta salida permite corroborar técnicamente que el correo fue interceptado sin errores.

[illegible]

Conclusión.

Validación Final: Entorno Sandbox (Mailhog):

Dada la restricción de las IPs residenciales, se procedió a una fase de validación en un entorno de desarrollo utilizando MailHog.

Resultado: Éxito absoluto. Al dirigir el tráfico hacia un recolector SMTP local, se confirmó que el vector de ataque es funcional.

Análisis del Vector: El correo se recibió con el formato visual de GitHub intacto, demostrando que si el atacante utilizara una IP comercial limpia o un relay autenticado, el correo evadiría los filtros técnicos y llegaría a la bandeja de entrada, quedando la seguridad enteramente en manos del criterio del usuario.

Diagnóstico De Bloqueo Perimetral:

Al intentar la entrega al dominio institucional (@upslp.edu.mx), se identificó un bloqueo en la capa de transporte:

status=bounced (550 5.7.1 Service unavailable, Client host blocked using Spamhaus)

Interpretación Técnica: El ataque fue mitigado por los filtros de Microsoft y Spamhaus. Este rechazo es una medida de seguridad que bloquea conexiones provenientes de IPs residenciales. Esto demuestra que la infraestructura de la UPSLP posee capas de protección robustas basadas en la reputación de la red de origen.

La ejecución de esta práctica de Ingeniería Social permitió analizar el ciclo completo de una amenaza, desde su concepción hasta su intercepción o entrega. El desarrollo del proyecto arrojó conclusiones críticas sobre la infraestructura de red y las capas de defensa actuales.

Uno de los aprendizajes más valiosos de esta auditoría fue la implementación de MailHog como entorno de Sandbox. Ante el bloqueo preventivo de los servidores de Microsoft (basado en la reputación de la IP residencial), MailHog se consolidó como la mejor alternativa técnica por las siguientes razones:

Validación de la "Capa de Aplicación": Confirmó que, si bien la Capa de Transporte falló (bloqueo de IP), el diseño visual y la lógica del ataque en la Capa de Aplicación eran 100% efectivos.

Inspección de Cabeceras: Facilitó la revisión de los headers del correo, demostrando que la herramienta SET es capaz de generar correos con una apariencia de alta fidelidad que el ojo humano difícilmente distinguiría de uno real.

Lecciones Aprendidas en Ciberseguridad

La Reputación es el Primer Escudo: El rechazo del servidor de la UPSLP mediante Spamhaus demostró que la seguridad institucional es robusta contra atacantes con infraestructura básica. Sin embargo, esto también resalta que un atacante con un Smart Host o una IP comercial limpia podría evadir esta primera capa.

El Factor Humano como Eslabón Crítico: El éxito de la entrega final en el entorno de MailHog evidencia que la ingeniería social sigue siendo el vector de entrada más peligroso. Una vez que el filtro técnico es superado, la seguridad depende enteramente del criterio del usuario.

Glosario técnico especializado

- MTA (Mail Transfer Agent): Software encargado de transferir mensajes de correo electrónico entre servidores utilizando el protocolo SMTP. En esta práctica, Postfix actuó como el MTA local responsable de procesar y despachar el ataque.
- smtpd (MTA Receive Daemon): Proceso del servidor Postfix que gestiona las conexiones entrantes. Es el primer punto de contacto que valida la conexión desde la herramienta de ataque (SET).
- cleanup (Message Canonicalization): Módulo interno de Postfix encargado de procesar los mensajes entrantes, añadir encabezados faltantes y asignar un Queue ID (identificador único) para asegurar la trazabilidad del correo.
- qmgr (Queue Manager): El "corazón" del servidor Postfix. Se encarga de gestionar la cola de mensajes, decidiendo cuándo y cómo intentar la entrega de un correo a su destino final.
- Queue ID: Código alfanumérico único (ej. 9EACEC6C2A) asignado a cada mensaje. Es fundamental para la auditoría forense, ya que permite rastrear el ciclo de vida completo de un correo específico en los registros de sistema.
- SMTP Error 550 5.7.1: Código de respuesta estandarizado que indica un rechazo permanente. El "5.7.1" especifica que el rechazo se debe a políticas de seguridad o falta de autorización del remitente.
- Bounced (Rebote): Estado de un correo que ha sido rechazado por el servidor de destino. Esto genera un evento de retorno donde el MTA local intenta notificar al remitente sobre la falla.
- RBL / Blacklist (Spamhaus): Base de datos en tiempo real que lista direcciones IP con mala reputación. En este análisis, fue el mecanismo utilizado por Microsoft para identificar la IP residencial del atacante y bloquear la intrusión.
- NDR (Non-Delivery Report): Informe de No Entrega. Es el mensaje automático que el servidor intenta enviar de vuelta al remitente (soporte@lab.local) para explicar por qué el correo falló.
- Removed (Purga de Cola): Acción final del MTA donde, tras fallar la entrega y la notificación de error, el registro se elimina de la memoria activa para optimizar los recursos del servidor y mantener la higiene de los logs.
- MailHog: Herramienta de código abierto diseñada para la fase de pruebas y desarrollo (Sandbox). Actúa como un servidor SMTP falso que captura todos los correos electrónicos enviados hacia él, permitiendo inspeccionar el contenido, las cabeceras y el formato HTML del ataque sin necesidad de una conexión a internet o de enfrentar filtros perimetrales reales. Es la alternativa más robusta para validar la fidelidad de un vector de ingeniería social en entornos controlados.